DOCUMENTO 09 · PROVA TÉCNICA

Anexos técnicos

Regras de segurança + exemplo real de auditoria (o que a AT valida).

1 · Regras Firestore — imutabilidade e isolamento (excerto)

```
match /audit_events/{eventId} {
  allow create: if request.auth ≠ null
    && request.resource.data.uid == request.auth.uid
    && request.resource.data.ts is number
    && request.resource.data.type is string;
  allow read: if request.auth ≠ null
    && (request.auth.token.email == 'admin@estudo360.pt'
        || request.auth.uid == resource.data.uid);
  allow update, delete: if false;   // imutável
}
match /auth_events/{eventId} {
  allow create: if request.auth ≠ null
    && request.resource.data.uid == request.auth.uid;
  allow read: if request.auth ≠ null
    && request.auth.token.email == 'admin@estudo360.pt';
  allow update, delete: if false;   // imutável
}
match /gabinete/{officeId}/{col}/{docId} {
  allow read: if request.auth.uid == officeId
    || isGabineteMember(officeId);
  allow create, update: if request.auth ≠ null
    && (request.auth.uid == officeId || isGabineteMember(officeId));
  allow delete: if request.auth ≠ null
    && (request.auth.uid == officeId || isGabineteMember(officeId));
}
```

2 · Exemplo real de audit_events

```
{
  "id": "a3k9x2b8m1c4",
  "ts": 1727960000000,
  "uid": "abc123uid",
  "email": "utilizador@gabinete.pt",
  "type": "edit_cliente",
  "detail": "Cliente Silva Lda",
  "empresaId": "cli_9f2a1b",
  "payload": { "nif": "500123456" }
}
{
  "id": "d7p2q9r4s8t1",
  "ts": 1727960100000,
  "uid": "abc123uid",
  "email": "utilizador@gabinete.pt",
  "type": "delete_cofre",
  "detail": "delete_cofre",
  "payload": { "titulo": "Acesso Banco XPTO", "categoria": "banco" }
  // segredo omitido → [oculto]
}
```

Cada escrita (`upsert*`) aplica carimbo de autor/data e registo de auditoria; cada eliminação grava retrato prévio com segredos mascarados.

3 · G1 + G2 + G3 — coberto a 100%

REQUISITO	IMPLEMENTAÇÃO	ESTADO
G1 · Rasto em todas as mutações	14 coleções com registo de auditoria (clientes, tarefas, obrigações, cofre, colaboradores, conversas, modelos, envios, tempos, atas, contactos, assuntos, alertas, ocorrências, documentos).	Feito
G2 · Prova antes de apagar	Eliminações gravam retrato prévio do registo, com segredos substituídos por [oculto].	Feito
G3 · Carimbo de autor/data	Carimbo automático de autor e data em todas as operações de escrita.	Feito

4 · Verificação técnica

TESTE	RESULTADO
Compilação + build	Construção de produção sem erros.
Regras Firestore publicadas	Imutabilidade verificada — alteração e eliminação bloqueadas.
Auditoria — 9 requisitos	4 conformes + 5 não aplicáveis justificados (ver Matriz 02).

> **Repositório de regras completo:** o ficheiro integral das regras Firestore é facultado à AT em conjunto com este anexo, a pedido.